MIZAN — solution note ميزان

Continuous HR policy assurance on synthetic Emirates data · github.com/BROCKUGANDA/mizan · demo: youtu.be/QE2QcfPyz8Y · MIT · synthetic data only

PROBLEM AND APPROACH

Sampling audits find 1 in 20 problems. MIZAN replaces sampling with a census: a deterministic engine checks every HR transaction against every written rule on every run, in seconds. Each exception explains itself in plain English or Arabic, cites the rule and the exact data that broke it, carries a severity with a stated rationale, routes to the right owner with a suggested corrective action — and waits for a person. Missing or ambiguous data yields "not evaluable" with a data-quality code, never a silent pass. The same inputs produce byte-identical output, verified by hash on repeated runs and in CI.

HOW IT WORKS

Inputs. `transactions.csv`, `employees.csv`, `policy_rules.md` (15 written sentences: 13 compiled rules, 1 definition, 1 human attestation, 1 scope note — coverage is measured, nothing silent), `finding_format.csv` (the output format with 5 worked examples).

Normalisation. Encoding/delimiter sniffing, RFC 4180 parsing, synonym-driven header and vocabulary mapping, per-column day-month inference (defaults flagged DQ-003), Asia/Dubai for offset-less timestamps, Arabic-Indic digits and separators, amounts parsed to integer fils (ambiguity → DQ-013, never rounded), unparseable rows quarantined with DQ codes and row numbers.

Engine. Twelve typed rule families (approval limit/count/chain, segregation of duties, documents, timing, sequence, eligibility, aggregate, duplicate, reference integrity, value bounds). Scope → data sufficiency → check → evidence. Census proof: applicable + not-applicable = total; evaluated + not-evaluable = applicable. Guards: flood guard per rule, run-level routing hold, not-evaluable spike guard, determinism self-check. Exception identity is SHA-256(tenant, transaction, rule, clause): re-runs upsert and append observations; changed evidence reopens closed exceptions.

Explanations. Eight parts (headline ≤90 chars, what broke, verbatim rule, evidence with breaching values highlighted, why it matters, what to do next, owner and severity, caveats) in English and Arabic with RTL layout and bidirectional isolates. The optional model can polish wording but is fact-locked to the evidence and never decides anything; with the model off, approved templates carry explanations unchanged.

Workflow. Severity rubric (base + ≤2 modifier steps), routing (override → table → family overlay → conflict-of-interest guard → fallback), SLA clocks on the versioned UAE business calendar with 75/100/150% escalation, countersign for High/Critical dismissals, typed confirmation + 10-second undo on bulk actions, If-Match concurrency (MZ-CONC-409).

Assurance. Hash-chained audit trail (tamper → safe halt), run manifest pinning every input and configuration hash, evidence packs with signed manifests, export validated against the worked examples before download.

RESULTS ON THE TRAINING DATA

Seed-42 pack: 1,061 transactions × 15 rule clauses = **15,915 checks in 0.3 s**; 6,415 applicable; 6,393 evaluated; 22 not evaluable; **49 findings** (5 Critical, 32 High, 12 Medium) + **13 data-quality exceptions** to stewardship. All five worked examples reproduce exactly on every scored column (FS-20 validator). Determinism: identical output hash across the seed process, repeated server runs and the offline CLI (`ecefa394…`). Measured precision is a Wilson lower bound on 49 labelled findings confirmed by the independent SQL oracle and boundary spot checks: **92.7% (49/49)**, shown on the overview with its provenance. The backtesting harness reports **100% mutation recall, 0 near-miss false positives, 9/9 format mutations, 7/7 metamorphic relations and 100% oracle agreement**. Audit readiness score: 80/100 on a fresh run (coverage 100%, evidence completeness 100%, governance 100%; decisions and timeliness rise as people work the queue).

RESPONSIBLE AI AND SECURITY

The engine decides; the model explains — and is optional, off by default, and fact-locked. Free text is data, never instructions. Nothing closes automatically; nothing writes to any source system; no write credentials exist. Conflict-of-interest, two-person rule approval, and High/Critical countersign are enforced in the API, not only the UI. The audit trail is append-only and hash-chained; verification failure enters safe halt (M5) and blocks writes. The demo is single-tenant; production row-level security is the deployment task recorded in DEVIATIONS. Logs are redacted; exports escape formula injection; uploads are size-, line- and row-limited with MIME sniffing. Pattern alerts are advisory only — never exported, never routed, no protected attributes. Small cells (<5) are suppressed. Synthetic data only: a PII scanner blocks real identifiers at upload. Secrets come from a vault; TLS 1.2+, encryption at rest, CSP/HSTS/frame-ancestors 'none' are configured in the deployment values. Dependency and container scans plus an SBOM per image are on the release checklist.

RUNNING INSIDE EMIRATES' ENVIRONMENT

Production deployment is three containers (web, API, workers) plus Postgres, Valkey-compatible cache and S3-compatible object storage with object lock; Docker Compose for a single-VM pilot, Helm for Kubernetes/OpenShift; fully offline (air-gapped profile bundles fonts, icons and calendars; telemetry to a local collector). Identity via OIDC with directory groups mapped to roles. Data in: scheduled read-only extracts to a landing zone, checksummed on arrival. Data out: notifications carry severity and a sign-on link only. AI: none required; optional local model on a GPU node or an approved in-country, zero-retention provider. Controls map to DESD/IA standards and ISO 27001; logs ship to the SIEM over syslog/OTLP. This repository runs the whole product as one process on SQLite; the production seams above are the gap list in `docs/DEVIATIONS.md`, not a claim of what is wired here.

REUSE AND PILOT PLAN

Everything that varies is versioned data: routing tables, calendars, grade ladders, synonyms, severity rubric, SLA policy, action library — editable without a deploy. A second business unit loads its own rule pack, routing and calendar with no code change; rule packs export and import with tests and a hash. The 12-week pilot (docs/PILOT_PLAN.md) runs weeks 1–2 onboarding, weeks 3–6 in shadow (target ≥90% measured precision on decided exceptions), weeks 7–12 assisted mode with weekly metrics: decision coverage 100%, noise ratio ≤10%, deadline adherence ≥90%, fix stickiness +20% quarter on quarter. Support: on-call rota, runbooks RB-01..08, escalation contacts agreed with HR compliance, HRIS and IT.

RUN IT

```
git clone https://github.com/BROCKUGANDA/mizan && cd mizan
bun install && bun run seed && bun run build && bun run start   # http://localhost:3000
bun run verify        # 12 assurance gates   bun test   bun run typecheck
bun run mizan hidden-test <test-file.csv>   # findings CSV + run manifest + checksums
```

EVIDENCE MAP

Criterion	Where a judge looks	Measured
Detection accuracy	`bun run mizan hidden-test <file>`; `bun run mizan bench oracle`	49 findings, 5/5 worked examples byte-identical, 100% SQL-oracle agreement, 0 near-miss false positives
Explanation and routing	Exception drawer: what broke, verbatim rule, evidence with sources, why it matters, next action, owner, severity rationale	8-part explanation on every finding, EN and AR; routing table version pinned in the run manifest
Responsible AI and security	Audit page (`mizan audit verify` offline), decision API, `docs/SECURITY.md`	Chain verified in-app and offline; 20 decision/run events on the demo state; If-Match, idempotency, conflict-of-interest and countersign enforced server-side; 0 auto-closed exceptions
Deployability and reuse	Rule studio (plain-English draft, ambiguity chips, generated tests, backtest), `docs/DEVIATIONS.md`	Sentence parsed in 0.07 s; backtest over 1,061 transactions in 0.42 s; overlap with R04 reported at Jaccard 1.0
Team and pilot readiness	`docs/PILOT_PLAN.md`, overview audit-readiness score, queue SLA clocks	Readiness 80/100 on a fresh run; SLA due dates on every exception from the versioned UAE calendar